

SOC TEMELLERİ

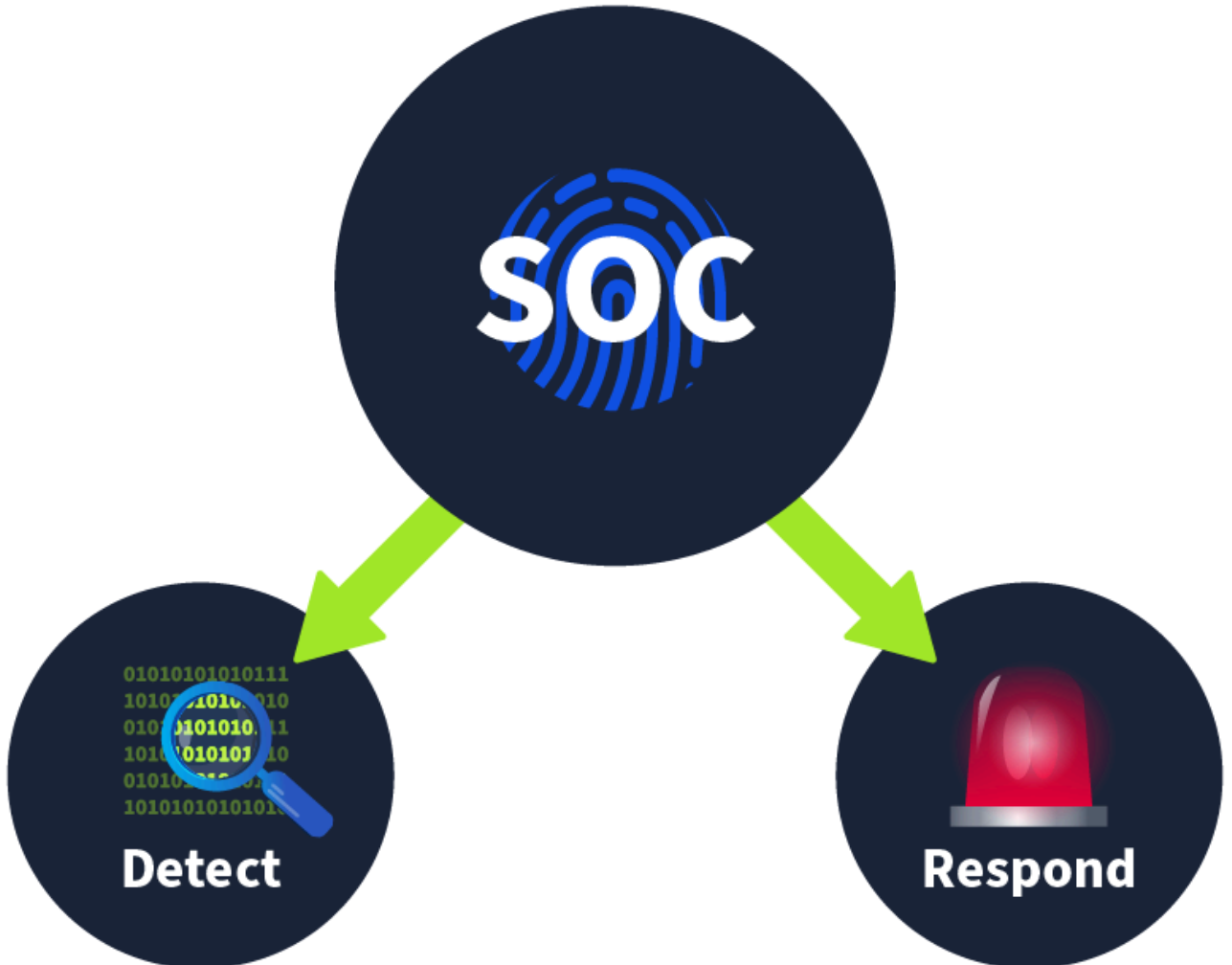
[Kaynak](#)

İÇERİK

1. SOC Operasyonlarının Temelleri: Detection, Response ve Kurumsal Mimari
2. SOC Mimarisinde "People" (İnsan) Faktörü ve Operasyonel Roller
3. SOC Operasyonlarında Süreç Yönetimi: Triyaj, Raporlama ve Müdahale
4. Technology (Teknoloji): SOC Operasyonlarının Teknik Omurgası

SOC Operasyonlarının Temelleri: Detection, Response ve Kurumsal Mimari

Modern siber güvenlik stratejisinin kalbi olan **SOC (Security Operations Center - Güvenlik Operasyonları Merkezi)**, bir organizasyonun dijital varlıklarını korumak için pasif savunmadan aktif izleme ve müdahaleye geçiş yaptığı merkezdir. Bu notlar, bir SOC'nin varlık sebebini, operasyonel hedeflerini ve bu hedeflere ulaşmak için kullandığı temel sacayaklarını teknik derinliğiyle analiz etmektedir.



SOC Operasyonel Odak Noktaları

Bir SOC ekibinin temel misyonu, **Detection (Tespit)** ve **Response (Müdahale)** mekanizmalarını kesintisiz ve işlevsel tutmaktır. Bu süreç, ağdaki tüm sistemlerin merkezi bir noktadan izlenmesini sağlayan güvenlik çözümlerinin (SIEM, EDR, XDR vb.) entegrasyonu ile yürütülür.

1. Detection (Tespit Etme) Süreçleri

Tespit aşaması, sadece bir alarmin çalması değil, ağ içerisindeki anomalilerin ve risk faktörlerinin proaktif olarak tanımlanmasıdır.

- **Vulnerability Detection (Zafiyet Tespiti):** Bir saldırganın yetki sınırlarını aşmak için istismar edebileceği yazılımsal veya yapılandırma kaynaklı zayıflıkların belirlenmesidir.
 - **Teknik Bağlam:** İşletim sistemleri (OS) veya uygulama katmanındaki yamalanmamış açıklar (örn: MS Windows üzerinde yayınlanmış bir CVE için yama yönetimi) SOC'nin doğrudan sorumluluğunda olmasa da, bu zafiyetlerin görünürlüğü SOC tarafından sağlanır. **Unpatched (Yamalanmamış)** bir sistem, tüm şirketin güvenlik seviyesini aşağı çeken en büyük risk faktörüdür.
- **Unauthorized Activity Detection (Yetkisiz Aktivite Tespiti):** Geçerli kimlik bilgilerinin (Username/Password) ele geçirilmesi durumunda yapılan girişlerin saptanmasıdır.
 - **Analitik Yaklaşım:** Burada "Geographic Location" (Coğrafi Konum) gibi meta-veriler kritiktir. Örneğin; bir kullanıcının İstanbul'dan giriş yaptıktan 5 dakika sonra Singapur'dan giriş yapması (**Impossible Travel**), hesabın ele geçirildiğine dair en güçlü kanıttır.
- **Policy Violation Detection (Politika İhlali Tespiti):** Kurumsal **Security Policy** (Güvenlik Politikası) çerçevesinde yasaklanmış eylemlerin izlenmesidir.
 - **Örnekler:** Korsan içerik indirilmesi veya şirket sırrı içeren dokümanların şifresiz/güvensiz kanallardan (örn: kişisel e-posta) dışarı çıkarılması. Bu, **Insider Threat** (İç Tehdit) analizinin bir parçasıdır.
- **Intrusion Detection (Sızma Tespiti):** Sistemlere veya ağa yönelik yetkisiz erişim teşebbüslerinin saptanmasıdır.
 - **Senaryo:** Bir Web Application'ın (Web Uygulaması) exploit edilmesi veya bir kullanıcının zararlı bir siteyi (Malicious Site) ziyaret ederek **Drive-by Download** yöntemiyle enfekte olması bu kategoriye girer.

2. Response (Müdahale) ve Olay Yönetimi

Tespit edilen bir olay (incident) sonrası devreye giren süreçtir. SOC ekibi, müdahale aşamasında sadece "yangını söndürmekle" kalmaz, aynı zamanda stratejik destek sağlar.

- **Incident Response (Olay Müdahale) Desteği:** Bir olay algılandığında, etkisini minimize etmek (containment) ve olayın kök nedenini anlamak için **Root Cause Analysis (RCA)** gerçekleştirmek SOC'nin asli görevleri arasındadır.

- **Teknik Süreklilik:** SOC ekibi, Incident Response (IR) ekibine veri akışı sağlayarak saldırıların ağdaki ayak izlerini (artifacts) takip etmelerine yardımcı olur.

SOC'nin Üç Temel Sacayağı: PPT Modeli

Bir SOC'nin olgunluk seviyesi (Maturity Level) ve operasyonel verimliliği, **People (İnsan)**, **Process (Süreç)** ve **Technology (Teknoloji)** bileşenlerinin uyumuna bağlıdır. Bu model, güvenliğin sadece bir yazılımdan ibaret olmadığını kanıtlar.



Bileşen	Açıklama ve Kritik Önemi
People (İnsan)	Güvenlik araçlarını kullanan, alarmları analiz eden ve stratejik kararlar alan uzman kadrodur. Teknik yetkinliğe sahip analistler olmadan en pahalı teknoloji bile sadece "gürültü" üretir.
Process (Süreç)	Bir olay anında ne yapılacağını belirleyen standart prosedürlerdir (SOP - Standard Operating Procedures). Müdahale hızı ve hata payının düşürülmesi, önceden tanımlanmış bu süreçlere bağlıdır.

Bileşen	Açıklama ve Kritik Önemi
Technology (Teknoloji)	Veri toplama (Log Collection), analiz (Correlation) ve engelleme (Prevention) araçlarıdır. SIEM, SOAR ve EDR gibi teknolojiler, insanın yetişemeyeceği hızda veriyi işler.

ÖNEMLİ NOT: Olgun bir SOC ortamı, bu üç bileşenin iç içe geçmesiyle oluşur. Teknoloji veri sağlar, Süreç bu verinin nasıl işleneceğini söyler, İnsan ise nihai hükmü vererek operasyonu yönetir.

Kritik Çıkarım: SOC, sadece saldırıları durduran bir birim değil; sürekli izleme, zafiyet yönetimi ve kurumsal uyumluluk (compliance) üzerinden şirketin genel risk profilini yöneten bir sinir merkezidir.

SOC Mimarisinde "People" (İnsan) Faktörü ve Operasyonel Roller

Güvenlik görevlerinin otomasyonu ne kadar gelişirse gelişsin, **People (İnsan)** bileşeni bir SOC'nin en kritik ve yeri doldurulamaz unsurudur. Teknoloji veri üretir, ancak bu veriyi anlamlandıracak ve stratejik kararlar alacak olan insan zekasıdır.

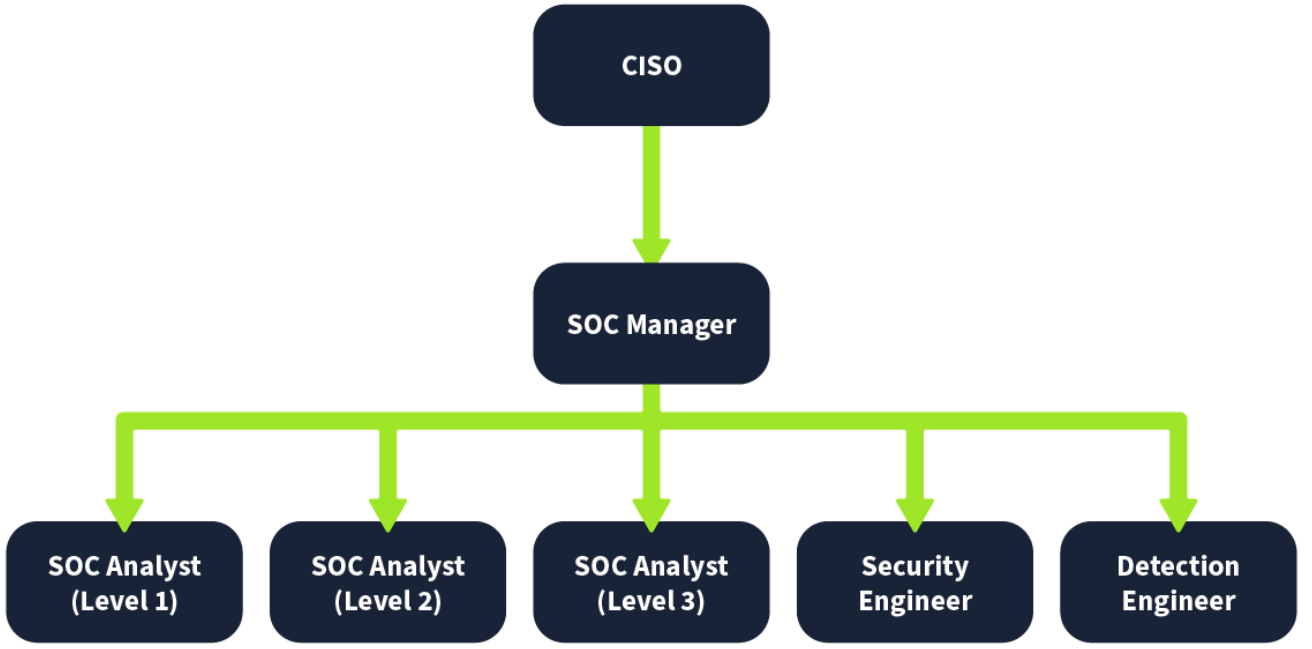
Neden İnsan Faktörü? (Gürültü ve Karar Mekanizması)

Güvenlik çözümleri (SIEM, EDR vb.) bir ağda binlerce "red flag" (şüpheli bayrak/uyarı) oluşturabilir. Bu durum, devasa bir **noise** (gürültü) oluşmasına yol açar.

- Analoji (İtfaiye Örneği):** Bir itfaiye ekibinin şehirdeki tüm yangın alarmlarının bağlı olduğu merkezi bir yazılıma sahip olduğunu düşünün. Onlarca uyarı aynı anda geliyor ancak olay yerine gidildiğinde çoğunun sadece yemek dumanından kaynaklandığı görülüyor. İnsan müdahalesi ve doğrulaması (Triage) olmazsa, tüm kaynaklar ve zaman bu asılsız ihbarlar (**False Positive**) için harcanır.
- SOC Gerçekliği:** İnsan müdahalesi olmayan bir SOC'de, ekip asıl tehlikeler yerine alakasız detaylara odaklanarak boğulur. İnsanlar, güvenlik çözümlerinin gerçekten zararlı aktiviteleri ayırt etmesini sağlar ve hızlı müdahale (**Prompt Response**) imkanı sunar.

SOC Takım Yapısı: Roller ve Sorumluluklar

Bir SOC ekibi, uzmanlık seviyelerine göre kademelendirilmiş bir hiyerarşi ile çalışır. Bu yapı, organizasyonun büyüklüğüne göre esneyebilir.



1. SOC Analyst (Level 1) - İlk Müdahale Uzmanı

Güvenlik çözümleri tarafından tespit edilen her şey ilk olarak L1 analistlerin önünden geçer.

- **Triage (Trijaj):** Gelen uyarıların temel analizini yaparak, tespitin gerçekten zararlı olup olmadığını (True Positive) veya yanlış alarm (False Positive) olup olmadığını belirlerler.
- **Raporlama:** Tespit edilen bulguları uygun kanallar üzerinden üst kademelere veya ilgili birimlere iletirler.

2. SOC Analyst (Level 2) - Derinlemesine Analiz Uzmanı

L1 analistin temel analizini aşan, daha karmaşık araştırmalar L2 kademesine devredilir.

- **Deep Investigation:** Tespit edilen tehdidin kökenine iner.
- **Data Correlation (Veri İlişkilendirme):** Birden fazla veri kaynağından (Loglar, Ağ trafiği, Endpoint verileri) gelen bilgileri birleştirerek korelasyon kurar ve saldırının tam resmini ortaya çıkarır.

3. SOC Analyst (Level 3) - Tehdit Avcısı ve Kriz Yöneticisi

Üst düzey deneyime sahip profesyonellerdir. Sadece alarm beklemek yerine proaktif çalışırlar.

- **Threat Hunting:** Ağ içerisinde henüz alarm oluşturmamış gizli tehdit göstergelerini (Indicators of Compromise - IoC) proaktif olarak ararlar.
- **Incident Response (IR):** Kritik seviyedeki vakalarda **Containment** (Sınırlandırma), **Eradication** (Tehdidi Temizleme) ve **Recovery** (Sistemi Geri Döndürme) süreçlerini yönetirler.

4. Security Engineer (Güvenlik Mühendisi)

Analistlerin üzerinde çalıştığı teknik altyapının mimarlarıdır.

- **Deployment & Configuration:** Güvenlik çözümlerinin (SIEM, Firewall, IDS/IPS vb.) kurulumunu, yapılandırmasını ve sorunsuz çalışmasını (maintenance) sağlarlar.

5. Detection Engineer (Tespit Mühendisi)

Güvenlik araçlarının arkasındaki mantığı (lojiği) inşa eden roldür.

- **Rule Creation:** Zararlı aktiviteleri yakalamak için özel korelasyon kuralları ve tespit algoritmaları geliştirirler. Genellikle L2 ve L3 analistlerle iç içe çalışırlar veya bağımsız bir birim olarak işlev görürler.

6. SOC Manager (SOC Yöneticisi)

Operasyonun yönetsel katmanıdır.

- **Process Management:** Ekibin takip ettiği süreçleri (Playbook'lar, SOP'lar) yönetir ve operasyonel desteği koordine eder.
- **C-Level İletişim:** Kurumun **CISO** (Chief Information Security Officer) birimiyle sürekli iletişim halindedir; SOC'nin güncel güvenlik durumu (**Security Posture**) ve operasyonel başarıları hakkında rapor sunar.

KRİTİK NOT: SOC rolleri statik değildir. Küçük bir organizasyonda bir kişi birden fazla rolü üstlenebilirken, devasa yapılarda her kademe kendi içinde özelleşmiş alt birimlere (örn: Malware Analyst, Digital Forensics Expert) ayrılabilir.

SOC Operasyonlarında Süreç Yönetimi: Triyaj, Raporlama ve Müdahale

Bir SOC'nin başarısı, teknolojinin ürettiği veriyi insanların hangi disiplinle işlediğine bağlıdır. **Process (Süreç)** katmanı, bir alarmin (alert) ham veri aşamasından çözüm (remediation) aşamasına kadar geçen yolculuğunu standardize eder.

Alert Triage: Analizin Temel Taşı

Alert Triage (Alarm Triyajı), SOC operasyonlarının ilk ve en kritik basamağıdır. Tıpkı bir hastane acil servisinde hastaların durumuna göre önceliklendirilmesi gibi, güvenlik alarmları da bu aşamada sınıflandırılır. Triyajın ana hedefi, alarmin ciddiyetini belirlemek ve kaynakların doğru yere yönlendirilmesini sağlamaktır.

Analiz sürecinde **5W (5N)** kuralı uygulanarak resmin tamamı netleştirilir:



5W Analiz Metodolojisi (Örnek Vak'a İncelemesi)

Senaryo: "GEORGE PC" isimli host üzerinde zararlı yazılım tespiti.

Soru	Teknik Karşılığı	Örnek Cevap / Analiz
What? (Ne?)	Olayın tanımı	Kurumsal ağ içindeki bir uç noktada (host) zararlı bir dosya tespit edildi.
When? (Ne Zaman?)	Zaman damgası (Timestamp)	Dosya, 5 Haziran 2024 saat 13:20'de tespit edildi. (Zaman analizi, saldırının kalıcılık sağlama süresini anlamak için kritiktir).
Where? (Nerede?)	Varlığın konumu	Tespit "GEORGE PC" üzerindeki spesifik bir dosya dizininde gerçekleşti.
Who? (Kim?)	İlgili aktörler	Dosya, George kullanıcısının oturumunda tespit edildi.
Why? (Neden?)	Kök neden (Root Cause)	Araştırma sonucunda dosyanın korsan yazılım indirme sitesinden indirildiği, kullanıcının ücretli bir yazılımı ücretsiz kullanma isteğiyle bu eylemi gerçekleştirdiği saptandı.

Reporting (Raporlama ve Eskalasyon)

Triyaj aşamasında zararlı olduğu kesinleşen (True Positive) bulgular, zamanında müdahale edilmesi için bir üst seviye analiste veya ilgili birime aktarılmalıdır.

- **Ticketing (Biletleme):** Her bulgu bir "Ticket" olarak sisteme kaydedilir ve ilgili kişiye atanır. Bu, operasyonel takip ve geriye dönük denetim (audit) için zorunludur.
- **Rapor İçeriği:** Teknik rapor sadece metinden ibaret olmamalıdır. 5W analizinin yanı sıra, analizin derinliğini gösteren log kayıtları ve aktivitenin kanıt niteliğindeki **ekran görüntüleri (screenshots)** mutlaka eklenmelidir. Kanıt dökümantasyonu, hem hukuki süreçler hem de teknik doğrulama için hayatidir.

Incident Response ve Digital Forensics

Bazı tespitler, basit bir temizlik işleminden fazlasını gerektiren kritik seviyeli olaylara işaret eder. Bu durumda süreç, standart analizin ötesine geçer:

1. Incident Response (Olay Müdahale)

L1 ve L2 analistlerin raporladığı kritik bulgular bir "Security Incident" (Güvenlik Olayı) olarak tanımlandığında, yüksek seviyeli ekipler müdahale sürecini başlatır. Bu süreç; saldırının yayılmasını durdurmayı (**Containment**), tehdidi tamamen kazımayı (**Eradication**) ve sistemleri güvenli hale getirip tekrar açmayı (**Recovery**) hedefler.

2. Digital Forensics (Adli Bilişim)

Nadir durumlarda, olayın derinliklerine inmek için detaylı bir adli inceleme gerekir.

- **Amacı:** Sistem veya ağ üzerindeki dijital kalıntıları (**Artifacts**) analiz ederek olayın kök nedenini (Root Cause) kesin olarak belirlemektir.
- **Teknik Derinlik:** Silinen dosyaların kurtarılması, bellek (RAM) dökümlerinin analizi ve kayıt defteri (Registry) incelemeleri gibi işlemlerle saldırganın izlediği yol haritası (TTP - Tactics, Techniques, and Procedures) ortaya çıkarılır.

DİKKAT: Bir SOC analisti için en büyük hata, "Why" sorusunun cevabını bulmadan alarmı kapatmaktır. Sorunun kaynağını (korsan yazılım sitesi vb.) belirlemeden yapılan müdahale, saldırının tekrar etmesine davetiye çıkarır.

Technology (Teknoloji): SOC Operasyonlarının Teknik Omurgası

Bir SOC mimarisinde doğru **People** (İnsan) ve **Process** (Süreç) bileşenlerine sahip olmak tek başına yeterli değildir; bu yapının "gözü, kulağı ve kası" olacak güvenlik çözümlerine ihtiyacı vardır. **Technology** katmanı, bir organizasyonun devasa ağındaki tüm cihazlardan gelen verileri merkezileştirerek manuel çabayı minimize eder ve müdahale hızını maksimize eder.

Merkezi Görünürlük ve Otomasyonun Önemi

Bir kurumun ağı yüzlerce sunucu, binlerce uç nokta ve onlarca uygulamadan oluşur. Her bir cihazı tek tek kontrol etmek (stand-alone monitoring) imkansızdır. Teknoloji bileşeni, bu dağıtık yapıyı tek bir merkezden (Centralized Monitoring) yönetmeyi ve tespit/müdahale süreçlerini otomatize etmeyi sağlar.

Kritik Güvenlik Çözümleri ve Fonksiyonel Analiz

1. SIEM (Security Information and Event Management)

SIEM, hemen hemen her SOC ortamının kalbidir. Temel işlevi, çeşitli **Log Source** (Log Kaynağı) üzerinden gelen verileri toplamaktır.

- **Correlation (Korelasyon):** SIEM'in asıl gücü budur. Birden fazla kaynaktan gelen verileri birleştirerek mantıksal bir çıkarım yapar.
 - *Teknik Örnek:* Bir Firewall'un "blokladığı trafik" verisi ile bir Domain Controller'ın "başarısız giriş" verisini birleştirerek bir **Brute Force** saldırısını tespit edebilir.
- **Modern Yetenekler:** Yeni nesil SIEM çözümleri sadece kural tabanlı (rule-based) çalışmaz; **UBA (User Behavior Analytics)**, **Threat Intelligence** (Tehdit İstihbaratı) ve **Machine Learning** algoritmalarını kullanarak anomali tespiti yapar.
- **DİKKAT:** Geleneksel olarak SIEM çözümleri esasen bir **Detection** (Tespit) aracıdır; kendi başına uç noktalarda aksiyon almaz, analisti uyarır.

2. EDR (Endpoint Detection and Response)

EDR, ağ trafiğinden ziyade doğrudan uç noktalara (host, server, workstation) odaklanır.

- **Deep Visibility:** Cihaz aktiviteleri üzerinde hem gerçek zamanlı hem de geçmişe dönük (historical) detaylı görünürlük sağlar.
- **Automated Response:** Bir dosyanın zararlı olduğu anlaşıldığında, analist sadece birkaç tıklama ile o cihazı ağdan izole edebilir (**Network Isolation**) veya zararlı süreci durdurabilir.
- **Araştırma:** Şüpheli bir sürecin hangi **parent process** (üst süreç) tarafından tetiklendiğini görmek için EDR vazgeçilmezdir.

3. Firewall (Güvenlik Duvarı)

İç ağ ile dış dünya (Internet) arasında bir bariyer görevi görür.

- **Traffic Filtering:** Gelen ve giden trafiği izleyerek yetkisiz erişimleri engeller.
- **Proaktif Koruma:** Üzerindeki tespit kuralları sayesinde, zararlı trafik iç ağdaki hedefine ulaşmadan önce tespit edilip bloklanabilir.

Diğer Yardımcı Güvenlik Çözümleri

Bir organizasyonun tehdit yüzeyine (**Threat Surface**) ve kaynaklarına bağılı olarak şu teknolojiler de ekosisteme dahil edilir:

- **IDS/IPS:** Ağ trafiğindeki saldırı imzalarını (signature) tespit eder ve (IPS ise) engeller.
- **EPP (Endpoint Protection Platform):** EDR'nin daha çok önleme (prevention) odaklı, geleneksel antivirüs özelliklerini de barındıran üst katmandır.
- **SOAR (Security Orchestration, Automation, and Response):** SIEM'den gelen alarmları alıp, Playbook'lar aracılığıyla diğer güvenlik araçlarını (EDR, Firewall vb.) otomatik olarak yöneten orkestra şefidir.
- **XDR (Extended Detection and Response):** EDR, SIEM ve Ağ güvenliğini tek bir platformda birleştiren genişletilmiş tespit ve müdahale teknolojisidir.

STRATEJİK NOT: SOC'de hangi teknolojinin konuşlandırılacağı bir lüks değil, kurumun maruz kaldığı risklerin ve eldeki bütçenin/insan kaynağının bir sonucudur. Yanlış yapılandırılmış veya "sahipsiz" bırakılmış bir teknoloji, sadece yanlış güven hissi verir. Sosyal mühendislik veya zero-day (sıfırıncı gün) saldırıları ancak bu teknolojilerin insan zekasıyla senkronize çalışmasıyla durdurulabilir.